Sergek: проверка перед финалом

Инженерный отчёт • 12 октября 2026 • Финал 16 октября • Кейс КРУ / Qostanai Hub

Главный результат: устранена возможность подделать Moodle-запуск общим ключом агента; добавлены серверная выдача, привязка к устройству, отзыв доступа, anchors и подпись отчёта. Исправлены ошибки навигации, обработки пакетов и хранения. Windows installer собран повторно.

Проверка	Подтверждённый результат
Python / adversarial	176 тестов, ошибок 0
Desktop / browser	16 / 12 тестов прошли
Moodle + Electron	5 вопросов, отправка, автоматическое завершение; ограничения ОС и камера отключены в тестовом профиле
Реальный телефон	4/4 эпизода в одной операторской записи; 0 ложных событий на 29,4 с отрицательного материала
Большой класс	Результаты разделены на контрольные пакеты и загрузку медиа; см. страницу 4

Готовность оценивается по доказательствам, а не числу функций. Физическая Windows-приёмка, университетская LMS/SSO и независимый AI holdout пока не заменены автоматическими тестами. Нулевое число ошибок во всех будущих условиях и 100 баллов жюри не гарантируются.

Основа проверки: полный предоставленный deep audit (9 страниц), применённый hardening patch, повторные локальные тесты, реальный Moodle 4.5.15, собранный Electron, изолированные HTTPS-нагрузки и добровольная запись оператора. Исходные цифры аудита не выдаются за новые результаты.

1. Исправленные риски

Приоритет от нарушения доверия к устойчивости и удобству.

Риск	Что изменено	Доказательство
P0: общий ключ выдаёт identity	Ed25519 private seed только Moodle; публичный ключ агенту; сервер регистрирует SG2	Чужие claims, legacy HMAC, невыданный nonce отвергнуты
P0: перенос запуска	Серверный grant связан с device ID, пользователем, quiz и одной session	Конкурентный bind, чужой device, revoke
P0: удаление хвоста журнала	Локальный count/head и подтверждённый сервером prefix	Tail deletion и cursor regressions
P0: изменение доказательства	SHA-256 commitment в цепочке + AES-GCM + проверка ZIP	Подмена, неверный event ID, архивные лимиты
P1: пустая/оборванная Moodle-страница	Ограниченное ожидание реально загруженного разрешённого документа	Полный медленный quiz E2E
P1: процесс уже завершился	Безопасный снимок Process metadata; self-test поддерживает dotnet host	Native regression: живой/завершённый дочерний процесс
P1: медиа задерживает контроль	Отдельный lease; delta sync; staging/шифрование вне DB lock	Нагрузки с отдельными измерениями
P1: диск заполняется	1 ГБ reserve, HTTP 507, неполнота, interrupted; terminal metadata отдельно	Имитация нехватки места и реальный неудачный soak
P1: потеря callback	Отдельный ограниченный пул сверяет точный Moodle attempt	Regression восстановления завершения
P1: шум панели	Блокировки в техническом журнале; review flags отдельно	Browser filtering, no missing-evidence polling
P1: большой класс	100 строк/страница, серверный поиск, общие счётчики	205 сессий API + браузерная навигация

Ошибки и неудачные прогоны сохранены. 500 клиентов с 1 МБ каждые 30 секунд заполнили диск и не прошли критерий p95; после этого добавлены reserve и staging. Этот прогон нельзя использовать как подтверждение масштаба.

2. Роли и отрицательные сценарии

Проверка проводилась с позиции студента, преподавателя, администратора, нарушителя и оператора.

Роль	Проверено	Граница
Студент	Вход Moodle, сохранение cookie, выбор quiz, согласие, Start attempt, 5 вопросов, отправка	Реальные OS restrictions проверяются оператором
Преподаватель	Auth, просмотр, review/note, технический фильтр, ошибки связи, PDF/JSON, подпись	Полноценные SSO/RBAC ещё нужны для пилота
Администратор	Enrollment, secret storage, revoke, URL/Origin, server-only credential	Нет аппаратной аттестации агента
Враждебный клиент	Чужая identity/device/session, replay, clock, malformed JSON, event collision, archive paths	Администратор ОС вне гарантированного периметра
Оператор	Диск, restart timestamps, camera cleanup, bounded queue, helper lease expiry	USB/RDP/secure desktop требуют физической матрицы

Покрытие Python: строки 73.5%, ветви 58.2%. Это покрытие измеряется только pytest, без кода, выполненного отдельными Electron/Moodle-процессами. Оно показывает оставшиеся пробелы, а не процент качества продукта.

Значимые регрессии: отклонённый пакет не расходует nonce; не меняет существующий журнал; старое active не восстанавливает terminal; start/end сохраняются; события review не переписывают исходный hash; legacy-сессии не получают ложную гарантию исторической полноты.

Секреты Moodle не принимаются API агента. Device key зашифрован локально; в списке устройств отсутствует. Подпись JSON проверяется независимо доверенным публичным ключом университета. Локальный отчёт агента имеет отдельный ключ и не становится университетским только по наличию поля public_key.

3. Moodle и нагрузка

Функциональная проверка и масштаб проверяются разными инструментами.

Собранный Electron + локальный Moodle: старт первой задачи 2904 мс в одном программном прогоне. Перед Start attempt сессия оставалась preflight. На каждом из 5 вопросов выдерживалась пауза 17 секунд; ответы отправлены, время начала/окончания записано, session завершилась автоматически. Это не измерение полного native/CV старта.

Сценарий	Клиенты	Длит.	Lease p95	Ошибки	Stale	Прошёл
Контроль / delta	500	600 с	6307.33 мс	14	278	Нет
Повтор control	500	600 с	7367.91 мс	20	368	Нет
Медиа 1 МБ/30 с	200	120 с	193.05 мс	1	0	Нет
Медиа 1 МБ/30 с	100	120 с	28.28 мс	0	0	Да
Прежний media stress	500	600 с	8696.47 мс	5467	2321	Нет

Метод: отдельный временный HTTPS-хаб, независимые Python driver-процессы, persistent connections, по 100 исходных событий на сессию; lease и Moodle status раз в 2 секунды. Control run не передаёт видео. Media run использует синтетические ZIP-файлы нужного объёма, без реальных кадров и AI-нагрузки.

Один ноутбук: 20 logical CPU, 15,7 ГБ RAM. Повтор control без полной сборки/CV также не прошёл: 20 ошибок, 368 stale, p95 lease 7367,91 мс, server-processing p95 219,07 мс; 500 завершений сохранены. Во время повтора был короткий .NET build. Это не LAN-тест трёх машин и не 500 камер; генератор и TLS работают на том же ноутбуке. Источник сетевой очереди требует отдельного профилирования.

Провал тяжёлой нагрузки сохранён: 5467 ошибок, 2321 stale, 499/500 сохранённых завершений. Схема хранения требует дискового планирования: 500 × 1 МБ × 20 эпизодов = около 10 ГБ только полезных медиа за 10 минут. Без ёмкости сервера такой профиль не допускается.

Прошедший профиль: 100 media-клиентов, 120 с, 12 600 запросов, 0 ошибок/stale, p95 lease 28,28 мс. Это предварительный профиль, не доказанный предел. Source hashes и условия каждого прогона сохранены в JSON.

Следующий gate: 3 компьютера в LAN, длительный soak и реальная аудитория. Пока нельзя объявлять такую приёмку завершённой.

4. Телефон, лицо и звук

Операторская запись проверяет конкретный телефон, а не общую точность AI.

Материал	Наблюдение
Реальная камера	Один добровольный участник; 96,39 с записи, 69,4 с ускоренной playback-шкалы
Разметка	Ручной просмотр ключевых кадров; переходы исключены; полный/частичный телефон, экран и задняя сторона
Эпизоды	4/4 получили phone_detected после временного правила
Отрицательные части	29,4 с; 0 ложных событий; это слишком мало для надёжного FPR/hour
Кадры 2 FPS	TP 49, FP 4, FN 14, TN 55

В кадрах были пропуски и краткие лишние bbox. Временное правило требует несколько свежих наблюдений и не превращает каждый bbox в отдельное нарушение. Кадровые показатели коррелированы; они не являются независимым статистическим испытанием. Скорость реакции реального времени этой ускоренной записью не доказывается.

В предоставленном аудите COCO128: 4/5 положительных изображений и 0/121 отрицательных. Это маленькая учебная выборка из train2017, а не независимый holdout. Три примера MiniFAS также не доказывают защиту от всех printed photo, replay video, virtual camera и deepfake.

Нужный следующий dataset: минимум 30 добровольцев, несколько камер и освещений; телефон front/back/partial, бумага/книга/кошелёк/очки, обычная работа. Отдельно photo/video replay и другой человек. Сначала фиксируется разметка и holdout, затем сравниваются модели. Измерять episode recall, false flags/hour, задержку, precision и различия условий.

Телефонные записи, фото и ключи остаются локально и не включаются в GitHub. Добавлены Capture-Phone-QA.py и Benchmark-Phone-Video.py для воспроизводимой приватной проверки. Длительный голос и шум требуют проверки в реальной аудитории; система выдаёт материалы преподавателю, а не автоматическое обвинение.

5. Windows, восстановление, выпуск

Что уже доказано программно и что должен подтвердить оператор.

Сценарий	Состояние
Guard self-tests	Живой/завершённый fixture-процесс; dotnet/self-contained host; оконные классификации
Lease helper	Heartbeat удержал lease >10 с; probe не продлевал; истечение и повторный release прошли
Камера/диск/queue	Регрессии cleanup, ошибки записи, bounded queue и incomplete report
USB / RDP / keys	Полная физическая приёмка этой новой сборки ещё нужна
Installer	Собран; Authenticode-сертификата нет, installer не подписан
Зависимости	pip-audit: известных уязвимостей нет; production npm: 0; dev-chain: 8 moderate записей одного sprintf-js advisory
CI	GitHub Windows run 38246425529 прошёл: backend, UI build, desktop, native isolated, browser

Dev advisory GHSA-hp3w-g68c-fv3c относится к sprintf-js в цепочке сборщика. На дату проверки patched release отсутствует. Рекомендация npm downgrade builder не применена вслепую. Сканирование не доказывает отсутствие неизвестных уязвимостей. Источник: github.com/advisories/GHSA-hp3w-g68c-fv3c.

В режиме strict приложение закрывает посторонние программы. Поэтому такой тест запускается самим оператором после сохранения работы через независимый Start-Sergek-Demo.cmd. Из редактора с активными документами глобальные ограничения не включались.

Проверить до сцены: обычное завершение, Ctrl+Alt+F12, USB read denial и восстановление, Alt+Tab/Win/PrintScreen, новая программа, RDP/remote process, второй монитор, потеря камеры и сети. Нужен факт ограничения и факт восстановления; наличие записи blocked само по себе не доказательство.

Изолированная offline backup/restore проверка прошла: перенос полного каталога под той же Windows учётной записью сохранил секрет, encrypted media, start/end, цепочку, anchor и доверенный report key. DPAPI привязан к учётной записи: одна база не восстанавливает ключи на другом компьютере. Clean VM/другая учётная запись, установка/upgrade/rollback ещё не проверены.

6. Как повысить оценку жюри

Исходно Sergek получил 64/85. Это обратная связь, а не новая прогнозная оценка.

Критерий	Было	Чем подкрепить улучшение
Понимание кейса	14/15	Показать реальный Moodle quiz: студент не вводит URL, режим или teacher password
Техническая реализация	17/20	SG2/device binding/revoke, negative tests, signed report, восстановление и проверяемые логи
Внедрение и эффект	14/20	Конкретный пилот КРУ: ответственный, 30 студентов, две сессии, baseline/после; не выдумывать экономию
Инновационность	8/15	Связная локальная архитектура и проверяемый жизненный цикл; объяснить полезность комбинации
Работа и демо	11/15	Один проход вход → старт → телефон → отправка → review → отчёт; локальная резервная запись

Финальная шкала добавляет защиту/ответы; доступный максимум не является обещанным баллом. Слабее всего подтверждены университетское внедрение, физическая приёмка и репрезентативная AI-оценка. Новые названия нейросетей не заменят эти доказательства.

OES на официальном сайте описывает камеру/звук/экран, антиспуфинг, desktop-контроль, remote/USB detection, мобильных клиентов и вторую камеру. Safe Exam Browser предлагает защищённую экзаменационную среду и LMS-интеграцию. Эти общие функции нельзя выдавать за уникальность Sergek.

Аргумент Sergek для данного кейса: локальное исполнение CV, университетский хаб, раздельные review/technical события, context clip до/после, серверный grant на конкретное устройство, открытые тесты и подписываемый отчёт. Превосходство по точности, стоимости и масштабу над OES не измерено.

Официальные источники, просмотрены 12.10.2026: oes.kz; Safe Exam Browser overview. Описания поставщиков не являются независимым сравнительным испытанием.

7. Қалған нақты қадамдар

Бағдарламалық дәлел, оператор сынағы және университет пилоты бөлек белгіленеді.

Қазір жасалғаны: сервер қолтаңбасы, компьютерге байланыстырылған рұқсат, рұқсатты тоқтату, журналдың anchor тексерісі, бейне хэшін тексеру, қолтаңбалы есеп, бөлек lease, өсіммен синхрондау, диск қоры, үлкен сыныпқа беттеу/іздеу. Телефонның төрт нақты эпизоды тіркелді.

Келесі қадам	Қабылдау дәлелі
Осы ноутбуктегі strict сынақ	Телефон/дыбыс/экран, USB оқылмауы, пернелер, бағдарламалар, қалыпты аяқтау және Windows қалпына келуі
Бөлек Windows VM	Таза орнату, жаңарту, rollback, авариялық шығу, сақталған параметрлердің қайтуы
Нақты аудитория	Көп камера, жарық, фон, адамдар; жалған оқиғалар/сағат және телефон эпизодтарын табу
КРУ тест ортасы	Нақты LMS нұсқасы, SSO, quiz саясаты, дерекке қолжетімділік және жауапты оператор
Өндірістік шығару	Installer қолтаңбасы, басқа компьютерге recovery, жеке рөлдер және қабылдау актісі

Қолмен тексеру реті: жұмысты сақтау → тәуелсіз таныстыру іске қосқышы → Moodle-ге кіру → фото → Start attempt → телефонның екі жағын көрсету → жауаптарды тапсыру → мұғалім панелінен оқиға/үзінді/дыбысты қарау → есеп → Windows қалпына келгенін тексеру. Бос сынақ флешкасын ғана пайдалану керек.

Демоға дейін: ноутбукты қуатқа қосу, бір монитор, камераны басқа бағдарлама ұстамағанын тексеру, кемінде бірнеше ГБ бос орын, зертхананы алдын ала іске қосу, 3 минуттық қорғауды таймермен өткізу. Қате болса, жасырмай себеп пен қалпына келу жолын көрсету.

Есеп пен installer дайын болғаны барлық сыртқы қабылдау аяқталды дегенді білдірмейді. Соңғы шешім: бақыланатын демоға дайындық едәуір күшейді; нақты құрылғы сынағы мен пилот нәтижесі толтырылуы керек. 100 баллға бағыт - әр уәденің қасында тексерілетін дәлел көрсету.